Praxisbericht: Datenschutz- und Informationssicherheitsaudits im Spannungsfeld von Digitalisierung und Regulierung

Max Peter
Matrikelnummer: 03732289
Studiengang: B.Sc. Politik & Technologie
Hochschule für Politik München (HfP)
TUM School of Social Sciences and Technology

Modul: Praxisprojekt (18 ECTS)
Betreuung: Julian Hofmann
Lehrstuhl für Recht und Sicherheit der Digitalisierung
Prof. Dr. Dirk Heckmann

Praxiszeitraum: 01.07.2021 – 31.12.2022
Praxispartner: cironet data security GmbH & Co. KG
Abgabedatum: 30. März 2026

---

1. Einleitung

Die zunehmende Digitalisierung wirtschaftlicher, politischer und gesellschaftlicher Prozesse hat zu einer erheblichen Ausweitung der Verarbeitung personenbezogener Daten geführt. Die Datenschutz-Grundverordnung (DSGVO) stellt seit ihrem Inkrafttreten im Jahr 2018 den zentralen regulatorischen Rahmen für den Schutz personenbezogener Daten in der Europäischen Union dar und harmonisiert damit das europäische Datenschutzrecht [1][2]. Gleichzeitig bilden Daten die Grundlage zahlreicher technologischer Innovationen – etwa im Bereich künstlicher Intelligenz, digitaler Plattformen oder Cloud-basierter Geschäftsmodelle – wie die Europäische Datenstrategie hervorhebt [1].

Organisationen stehen damit vor der Herausforderung, regulatorische Anforderungen mit technischer Innovation in Einklang zu bringen.

Der vorliegende Praxisbericht dokumentiert meine Tätigkeit als zertifizierter Datenschutzauditor und Berater bei der cironet data security GmbH & Co. KG im Zeitraum von Juli 2021 bis Dezember 2022. Im Zentrum stehen zwei Praxisprojekte: die Beratung der **ICO AG** (technologieorientiertes Zertifizierungsunternehmen mit Blockchain- und Cloud-Infrastrukturen) sowie der Partei **dieBasis** (politische Organisation mit dezentraler föderaler Struktur). Beide Organisationen erforderten die praktische Umsetzung der DSGVO in unterschiedlichen technologischen und organisatorischen Kontexten.

Drei zentrale Fragestellungen leiten den Bericht:

1. *Wie wird die DSGVO in der organisatorischen Praxis wahrgenommen und umgesetzt?*
2. *Welche Herausforderungen ergeben sich bei internationalen Datenübermittlungen (insbesondere nach dem Schrems-II-Urteil)?*
3. *Welche Rolle spielen technische Lösungsansätze wie Pseudonymisierung und Verschlüsselung im praktischen Datenschutz?*

Die Struktur orientiert sich an den Vorgaben der HfP: Nach Vorstellung des Praxispartners (Kapitel 2) und Beschreibung meiner beruflichen Tätigkeit (Kapitel 3) werden die beiden Praxisprojekte dargestellt (Kapitel 4), gefolgt von einer kritischen Reflexion (Kapitel 5) und einem abschließenden Fazit (Kapitel 6).

---

2. Praxispartner und berufliche Tätigkeit

2.1 cironet data security GmbH & Co. KG

Die cironet data security GmbH & Co. KG ist ein IT-Beratungsunternehmen mit Sitz in München. Das Leistungsspektrum umfasst Datenschutz-Audits nach DSGVO, Implementierung von Informationssicherheitsmanagementsystemen (ISMS) nach ISO/IEC 27001 und CISIS12, Datenschutz-Folgenabschätzungen, Tätigkeit als externer Datenschutzbeauftragter sowie Compliance-Beratung für innovative Technologien (Blockchain, Cloud-Computing, künstliche Intelligenz).

Die cironet unterstützt im vorallem Organisationen mit hohem technologischen Innovationsgrad, die vor der anspruchsvollen Herausforderung stehen, innovative Technologien mit strengen DSGVO-Anforderungen zu vereinbaren. Die Beratungsarbeit erfordert eine **interdisziplinäre Perspektive**

aus Recht, Technik und Organisation[3]. Das Datenschutzrecht ist jedoch bei weitem nicht ausschließlich juristisch: Es umfasst die Bewertung technischer Schutzmechanismen (Verschlüsselung, Pseudonymisierung), die Analyse von IT-Infrastrukturen, die Entwicklung organisatorischer Prozesse sowie das Verständnis politisch-gesellschaftlicher Dimensionen (Grundrechtsdimension, digitale Souveränität).

In diese interdisziplinäre Anforderung spiegelt sich für mich die Ausrichtung meines Studiums der Politik & Technologie wider. Politikwissenschaftliche Perspektiven werden mit technologischem Verständnis verbunden, um komplexe Fragen an der Schnittstelle von Politik, Recht und Technologie zu analysieren.

2.2 Rolle als Datenschutz- und Informationssicherheitsauditor

Meine Haupttätigkeit umfasste folgende Aufgaben:

- **Datenschutz-Audits**: Systematische Überprüfung der DSGVO-Compliance, Identifikation von Schwachstellen und Risiken, Bewertung bestehender Maßnahmen.
- **Analyse von Datenverarbeitungsprozessen**: Detaillierte Untersuchung, welche personenbezogenen Daten zu welchen Zwecken verarbeitet werden, Prüfung der Rechtsgrundlagen (Art. 6 DSGVO), Bewertung der Verhältnismäßigkeit.
- **Erstellung von Verzeichnissen von Verarbeitungstätigkeiten (Art. 30 DSGVO)**: Strukturierte Erfassung aller Datenverarbeitungsvorgänge mit Angaben zu Zwecken, Kategorien betroffener Personen, Empfängern, Löschfristen und technisch-organisatorischen Maßnahmen (TOMs).
- **Bewertung technisch-organisatorischer Maßnahmen (Art. 32 DSGVO)**: Prüfung der Angemessenheit implementierter Sicherheitsmaßnahmen unter Berücksichtigung des Stands der Technik, der Implementierungskosten und der Risiken für Betroffene.
- **Unterstützung bei Datenschutz-Folgenabschätzungen (DSFA, Art. 35 DSGVO)**: Risikoanalysen bei Datenverarbeitungen mit hohem Risiko, Entwicklung von Maßnahmen zur Risikominimierung.
- **Beratung zu Informationssicherheitsmanagementsystemen**: Unterstützung bei der Implementierung von ISMS nach ISO/IEC 27001 oder CISIS12[4], Integration von Datenschutz- und Informationssicherheitsanforderungen.

- **Schulung und Sensibilisierung**: Awareness-Trainings für Mitarbeiter, Entwicklung von Schulungskonzepten.

Die Arbeit orientierte sich an verschiedenen regulatorischen Rahmenwerken: DSGVO, BDSG, ISO/IEC 27001:2013, CISIS12 (integrierter Standard für Datenschutz und Informationssicherheit in 12 Schritten)[4] sowie BSI IT-Grundschutz und weiteren.

2.3 Externe Datenschutzbeauftragtenfunktion

In beiden Hauptpraxisprojekten (ICO AG und Partei dieBasis) übernahm ich die Rolle des **externen Datenschutzbeauftragten** gemäß Art. 37 ff. DSGVO mit folgenden Aufgaben (Art. 39 DSGVO):

- Unterrichtung und Beratung der verantwortlichen Stelle über datenschutzrechtliche Pflichten (DSGVO, BDSG)
- Überwachung der Einhaltung (Monitoring der Compliance, Überprüfung von Datenschutzgrundsätzen und TOMs)
- Beratung zu Datenschutz-Folgenabschätzungen (DSFA)
- Zusammenarbeit mit der Aufsichtsbehörde (Anlaufstelle für die Datenschutz-Aufsichtsbehörde)
- Anlaufstelle für Betroffene (Beantwortung von Anfragen zu Betroffenenrechten: Auskunft, Berichtigung, Löschung)

Die Rolle erfordert ein hohes Maß an Kommunikationsfähigkeit und Vermittlung zwischen rechtlichen Anforderungen und praktischer Umsetzbarkeit, zwischen Unternehmensinteressen und Datenschutzanforderungen, zwischen technischen Möglichkeiten und rechtlichen Notwendigkeiten.

---

3. Praxisprojekte

3.1 ICO AG – Datenschutz in einem Blockchain- und Zertifizierungsunternehmen

3.1.1 Unternehmensprofil und technologische Herausforderungen

Die ICO AG (International Certification Organization) betreibt eine digitale Plattform für Online-Prüfungen und verifizierbare Zertifikate. Die technologische Infrastruktur basiert auf:

- **Cloud-basierter Architektur**: Microsoft Azure (Datenbanken: Azure Cosmos DB, Speicher: Azure Blob Storage, Webapplikationen: Azure Web App Services)
- **Kognitive Dienste für biometrische Authentifizierung**: Microsoft Azure Face API zur Gesichtserkennung bei Prüfungsteilnehmern (besondere Kategorie personenbezogener Daten nach Art. 9 DSGVO)
- **Blockchain-basierte Zertifikatsverifizierung**: Kryptographische Hash-Werte ermöglichen Echtheitsprüfung ohne Offenlegung vollständiger Zertifikatsdaten

Ich war vom 21.07.2021 bis 2023 als externer Datenschutzbeauftragter beauftragt und verantwortete die Aufstellung und kontinuierliche Pflege der gesamten Datenschutzdokumentation (227 Seiten, finalisiert Juli 2023).

3.1.2 Datenschutzrechtliche Herausforderungen und Lösungen

Die Verarbeitung personenbezogener Daten erfolgte in verschiedenen Bereichen:

Datenschutzaspekt	**Herausforderung und Lösung**
Rechtsgrundlage für **biometrische Daten**	Verarbeitung besonderer Kategorien (Art. 9 DSGVO). **Lösung**: Einwilligung (Art. 9 Abs. 2 lit. a) + vertragliche Notwendigkeit (Art. 9 Abs. 2 lit. b) für Prüfungskontext.
Transparenz	Information gemäß Art. 13, 14 DSGVO. **Lösung**: Detaillierte Datenschutzerklärung, spezifische Informationen zur Online-Prüfung.
Datenminimierung	Erhebung biometrischer Daten nur soweit erforderlich. **Lösung**: Umwandlung von Gesichtsbildern in kryptographische Templates (SHA256), keine dauerhafte Speicherung der Originalbilder.

Speicherbegrenzung	Festlegung angemessener Löschfristen. **Lösung**: Pseudonymisierung aller Sitzungsdaten nach 180 Tagen, dauerhafte Speicherung nur der Templates zur Verifizierung.

Table 1: Datenschutzrechtliche Herausforderungen bei der ICO AG

3.1.3 Internationale Datenübermittlungen und Drittstaatentransfers

Ein zentraler Schwerpunkt war die Analyse internationaler Datenübermittlungen. Das Schrems-II-Urteil (EuGH, C-311/18, 16.07.2020)[5] erklärte das EU-US Privacy Shield für ungültig und stellte hohe Anforderungen an Standardvertragsklauseln (SCC): Bloße vertragliche Garantien reichen nicht aus, wenn das Recht des Drittstaates staatlichen Behörden weitreichende Zugriffsmöglichkeiten einräumt (US CLOUD Act, FISA 702).

Praktische Umsetzung bei der ICO AG:

1. **Analyse der Datenflüsse**: Systematische Erfassung aller Datenübermittlungen in Drittstaaten (USA: Microsoft, Amazon Web Services, Zoom, Cloudflare, Twilio SendGrid)
2. **Bewertung des Schutzniveaus**: Prüfung nach Art. 45/46 DSGVO – für USA waren zusätzliche Maßnahmen erforderlich
3. **Implementierung ergänzender Maßnahmen (gemäß EDPB-Empfehlungen)**:
    - Verschlüsselung von Daten im Transit und im Ruhezustand (Encryption in transit and at rest)
    - Verwendung europäischer Rechenzentren, wo möglich
    - Vertraglich vereinbarte Datenlokalisierung innerhalb der EU/EWR
    - Abschluss neuer Standardvertragsklauseln (EU SCCs 2021)
    - Dokumentation der Transfer Impact Assessments (TIA)
4. **Auftragsverarbeitungsverträge (AVV)** nach Art. 28 DSGVO mit allen Auftragsverarbeitern

Die vollständige Datenschutzdokumentation (227 Seiten) umfasste: Ein Verzeichnis von Verarbeitungstätigkeiten (Art. 30 DSGVO), detaillierte TOMs, Übersicht aller Auftragsverarbeiter und Drittstaatentransfers, Standardvertragsklauseln und TIAs, Datenschutzerklärungen.

3.1.4 Technischer Datenschutz: Pseudonymisierung und Verschlüsselung

Pseudonymisierung biometrischer Daten (Art. 4 Nr. 5 DSGVO):

- Erstellung kryptographischer Templates (Hash-Werte) aus Gesichtsbildern
- Keine dauerhafte Speicherung der Originalbilder
- Templates sind nicht reversibel (Rekonstruktion des Originalbildes unmöglich)
- Nutzung nur für Authentifizierung und Zertifikatsverifizierung

Verschlüsselung (Art. 32 Abs. 1 lit. a DSGVO):

- Transport Layer Security (TLS) für alle Datenübertragungen
- Encryption at rest für alle in Azure gespeicherten Daten
- E-Mail-Verschlüsselung (S/MIME) für vertrauliche Kommunikation
- Festplattenverschlüsselung (BitLocker, FileVault) auf Arbeitsgeräten

Zugriffskontrollen:

- Rollenbasierte Zugriffskontrolle (RBAC) für Administratoren
- Multifaktor-Authentifizierung (MFA) bei erhöhtem Schutzbedarf
- Protokollierung von Zugriffen auf personenbezogene Daten
- Minimale Anzahl an Administratoren mit privilegiertem Zugang

Lösungskonzept: Session-Daten (Löschung nach Browser-Schließung), temporäre Prüfungsdaten (Pseudonymisierung nach 180 Tagen), Log-Dateien (Aufbewahrung max. 12 Monate), Zertifikatsdaten (Aufbewahrung solange Konto aktiv).

3.2 Partei dieBasis – Datenschutz und IT-Sicherheit in einer politischen Organisation

3.2.1 Organisationsstruktur und IT-Sicherheitsvorfälle

Der Bundesverband der Partei **dieBasis** ist eine politische Organisation mit stark dezentraler, föderaler Struktur (zahlreiche Landesverbände, regionale Gliederungen). Ich war dort vom 01.09.2021 bis 31.12.2022 als **ehrenamtlicher externer Bundesdatenschutzbeauftragter** tätig (**Pro-Bono-Engagement**).

Bei Beginn meiner Tätigkeit im September 2021 dokumentierte ein internes Sicherheitsteam schwerwiegende Sicherheitsmängel und konkrete Sicherheitsvorfälle. Auf Basis der Sicherheitsprotokolle vom August 2021 führte ich ein Kurz-Audit der IT-Infrastruktur durch[6] mit folgenden Ergebnissen.

Schwachstelle	**Risikobewertung**
Fehlende **IT-Leitlinien und Richtlinien**	Schwere Nicht-Konformität. Keine dokumentierten Vorgaben für sicheren IT-Betrieb. Haftungsrisiken für Vorstände.
Fehlendes **IT-Sicherheitskonzept**	Keine systematische Sicherheitsarchitektur. Schwere „Nicht-Konformität“ nach ISO 27001 und Art. 32 DSGVO.
Fehlende **Netzwerk-Segmentierung**	Keine Trennung der Produktiv-/Test-/Entwicklungsumgebung. Angriffe konnten sich unkontrolliert ausbreiten.
Gemeinsame *Privilegierte* -Zugänge	Gemeinsam genutzte Admin-/Root-Zugänge. Keine individuelle Zurechenbarkeit. Verstoß u.a. gegen Segregation of Duty.
Fehlende F**irewall-Konfiguration**	Firewall-Funktionalität des Cloud-Anbieters nicht konfiguriert. Produktivumgebung ohne Schutz.
Unverschlüsselte Kommunikation	Interner Netzwerkverkehr, E-Mail-Server, LDAP-Server ohne Verschlüsselung. Hohe Vertraulichkeitsrisiken.
Unzureichendes **Backup-** **Konzept**	Backups nur von Server-Images, nicht von Nutzdaten und Dienste-Konfiguration Keine Verschlüsselung. Faktisch keine Datensicherung.
Fehlende Redundanz	Keine Hochverfügbarkeit. Single Points of Failure.

Table 2: Hauptschwachstellen der IT-Infrastruktur der Partei dieBasis (Stand September 2021)

Hinzu kamen konkrete **Sicherheitsvorfälle**: Nicht autorisierte Datenexporte aus dem Mitgliederverwaltungssystem (MVS) im Februar 2022 mit Zugriff auf bis zu 10.000 Mitgliederdatensätze, Erteilung zahlreicher nicht nachvollziehbarer Berechtigungen, Verdacht einer internen Kompromittierung der IT. Diese stellten potentiell **meldepflichtige Datenschutzverletzungen** im Sinne des Art. 33 DSGVO dar.

3.2.2 Incident Response und Einführung eines ISMS

Als Bundes-Datenschutzbeauftragter unterstützte ich das interne Sicherheitsteam und erarbeitete einen strukturierten Maßnahmenplan:

Sofortmaßnahmen (September – Oktober 2021):

- Eindämmung der akuten Sicherheitsvorfälle
- Zurücksetzen aller Passwörter
- Entzug nicht autorisierter Berechtigungen
- Aktivierung und Konfiguration der Firewall
- Implementierung von Verschlüsselung für kritische Dienste

Mittelfristige Maßnahmen (November 2021 – Juni 2022):

- Aufbau einer neuen, sauber strukturierten IT-Infrastruktur mit Netzwerk-Segmentierung und Redundanzen
- Migration produktiver Systeme in die neue Umgebung
- Entwicklung eines Berechtigungskonzepts mit individuellen Zugängen
- Implementierung eines Backup-Konzepts mit Verschlüsselung
- Erstellung grundlegender IT-Richtlinien

Strategische Maßnahmen (Konzeption Juni 2022):

- Einführung eines integrierten Datenschutz- und Informationssicherheitsmanagementsystems nach CISIS12[4] (Compliance and Information Security in 12 Steps)
- Etablierung eines Koordinatorenmodells mit Landes-Datenschutzbeauftragten (LDSB)
- Entwicklung von Schulungskonzepten für Administratoren und Mitarbeiter

- Aufbau eines Incident-Response-Managements

Im Juni 2022 entwickelte ich ein umfassendes **Datenschutz- und IT-Sicherheitskonzept** (35 Seiten) [8]: Datenschutzleitlinie, organisatorische Strukturen (Rollen und Verantwortlichkeiten), Verzeichnis von Verarbeitungstätigkeiten (Art. 30 DSGVO), umfassende TOMs (Art. 32 DSGVO), Risikomanagement-Prozess, Einführungsstrategie für CISIS12.

CISIS12 wurde gewählt, weil es speziell für Organisationen konzipiert ist, die sowohl Datenschutz- als auch Informationssicherheitsanforderungen erfüllen müssen, aber nicht die Ressourcen für eine vollständige ISO 27001-Zertifizierung haben. CISIS12 integriert die DSGVO-Anforderungen (insbesondere Art. 24, 25, 32) mit den ISMS-Prinzipien in einem schlanken 12-Schritte-Modell[4].

3.2.3 Herausforderungen im politischen Kontext

Die Arbeit für eine politische Organisation brachte spezifische Herausforderungen mit sich:

- **Ressourcenknappheit**: Begrenzte finanzielle und personelle Ressourcen, IT-Infrastruktur und Datenschutz oft mit ehrenamtlicher Arbeit und begrenzten Budgets
- **Dezentrale Entscheidungsstrukturen**: Basisdemokratische Strukturen bedeuteten langwierige Abstimmungsprozesse, Verzögerung dringend notwendiger Maßnahmen
- **Politische Sensibilität**: Mitgliederdaten politischer Parteien sind besonders sensibel (Art. 9 Abs. 1 DSGVO: besondere Kategorien personenbezogener Daten – politische Einstellungen)
- **Hohe Fluktuation**: Unklare Zuständigkeiten im Bereich IT-Administration erschwerten die Kontinuität der Sicherheitsmaßnahmen
- **Vertrauensverluste durch Vorfälle**: Sicherheitsvorfälle vom Februar 2022 führten zu erheblichen Vertrauensverlusten innerhalb der Partei

Diese Erfahrungen zeigten mir, dass Datenschutz und IT-Sicherheit nicht nur technische und rechtliche Herausforderungen sind, sondern auch organisatorische Reife, Managementunterstützung und ausreichende Ressourcen erfordern.

---

4. Reflexion und Erkenntnisse

4.1 DSGVO als Governance-Instrument

In der organisatorischen Praxis wird die DSGVO häufig ambivalent wahrgenommen:

- **Compliance-Belastung**: Umfangreiche Dokumentationspflichten (Art. 30 DSGVO, Datenschutzerklärungen, TOMs) werden als zeitaufwändig und ressourcenintensiv wahrgenommen. Die Drohung hoher Bußgelder (bis zu 20 Mio. Euro oder 4% des weltweiten Jahresumsatzes, Art. 83 Abs. 5 DSGVO) erzeugt Verunsicherung.
- **Governance-Instrument**: Bei näherer Betrachtung trägt die DSGVO jedoch zur Professionalisierung organisatorischer Datenmanagementprozesse bei. Die systematische Erfassung aller Datenverarbeitungsvorgänge, die Entwicklung von Löschkonzepten, die Implementierung von Zugriffskontrollen und die Etablierung von Prozessen zur Wahrnehmung von Betroffenenrechten führen zu verbesserter Daten-Governance[9]. Organisationen gewinnen einen besseren (oder erstmals) Überblick über ihre Datenverarbeitungen und Datenbestände.

In meiner praktischen Arbeit zeigte sich diese Ambivalenz konkret:

Während initial oft nicht unerhebliche Widerstände gegen „zusätzliche Arbeit" bestanden, entwickelte sich im Laufe der Projekte ein Verständnis dafür, dass strukturierte Datenschutz- und IT-Sicherheitsprozesse nicht nur rechtliche Anforderungen erfüllen, sondern auch operative Vorteile bieten (Reduzierung von Sicherheitsvorfällen, klarere Verantwortlichkeiten, bessere Nachvollziehbarkeit und event. sogar weniger Aufwand).

4.2 Drittstaatenübermittlungen: Rechtsunsicherheit und faktische Abhängigkeiten

Das **Schrems-II-Urteil** (EuGH, C-311/18, 16.07.2020)[5] führte zu erheblichen praktischen Herausforderungen:

Der EuGH erklärte das EU-US Privacy Shield für ungültig und stellte hohe Anforderungen an Standardvertragsklauseln. Bloße vertragliche Garantien reichen nicht aus, wenn das Recht des Drittstaates staatlichen Behörden weitreichende Zugriffsmöglichkeiten einräumt (US CLOUD Act, FISA 702).

Praktische Konsequenzen: Notwendigkeit detaillierter Analyse aller Datenflüsse in Drittstaaten, Durchführung von Transfer Impact Assessments (TIA) für jede Übermittlung, Implementierung ergänzender technischer Maßnahmen (Verschlüsselung, Pseudonymisierung), Prüfung der Datenlokalisierung in der EU/EWR, Abschluss neuer Standardvertragsklauseln (EU SCCs 2021), umfangreiche Dokumentation.

Spannungsfeld: Viele Organisationen sind faktisch auf internationale Cloud-Infrastrukturen angewiesen. Die großen Cloud-Anbieter (Microsoft Azure, Amazon AWS, Google Cloud) sind überwiegend US-amerikanische Unternehmen. Europäische Alternativen (z.B. OVH, Hetzner) bieten oft nicht den gleichen Funktionsumfang oder sind kostspieliger. Einerseits sind die rechtlichen Anforderungen nach Schrems II sehr hoch, andererseits ist ein vollständiger Verzicht auf Cloud-Dienste US-amerikanischer Anbieter für viele Organisationen unrealistisch.

4.3 Pseudonymisierung: Potenziale und Grenzen

Die DSGVO unterscheidet zwischen **Anonymisierung** (Daten fallen nicht mehr in den Anwendungsbereich der DSGVO, Erwägungsgrund 26) und **Pseudonymisierung** (Art. 4 Nr. 5 DSGVO – Daten bleiben personenbezogene Daten).

Bei der ICO AG wurde **Pseudonymisierung** bei biometrischen Daten eingesetzt: Gesichtsbilder wurden in „kryptographische Templates“ (SHA256 Hash-Werte) umgewandelt. Diese Templates ermöglichen die Wiedererkennung, aber nicht die Rekonstruktion des Originalbildes. Dies ist ein Beispiel für eine **wirksame Pseudonymisierung**.

Grenzen: Die rechtliche Abgrenzung ist in der Praxis oft unklar. Wann ist eine Anonymisierung „**irreversibel**"? Selbst pseudonymisierte Daten können unter bestimmten Umständen **re-identifiziert** werden, insbesondere wenn zusätzliche Informationen hinzugezogen werden. Die Anonymisierungs-Forschung zeigt, dass vermeintlich anonyme Datensätze durch Kombination verschiedener Attribute oft doch Personen zugeordnet werden können[10].

In der Praxis führen diese Unsicherheiten dazu, dass Organisationen Anonymisierung oft nur eingeschränkt einsetzen. Pseudonymisierung wird als sichererer Weg wahrgenommen, auch wenn die Daten dann weiterhin der DSGVO unterliegen. Technische Lösungen können Datenschutzrisiken **reduzieren, aber nicht eliminieren** – sie müssen stets in ein **Gesamtkonzept** aus rechtlichen, technischen und organisatorischen Maßnahmen eingebettet sein.

4.4 Interdisziplinäre Perspektive: Recht, Technik und Organisation

Die praktische Datenschutzarbeit verdeutlichte die Notwendigkeit einer **genuinen interdisziplinären Perspektive**. Keine der drei Dimensionen – Recht, Technik, Organisation – kann isoliert betrachtet werden.

Beispiel Verschlüsselung:

- Rechtlich ist Verschlüsselung eine wichtige Maßnahme zur Sicherheit der Verarbeitung (Art. 32 Abs. 1 lit. a DSGVO).
- Technisch gibt es verschiedene Verschlüsselungsverfahren mit unterschiedlichen Sicherheitsniveaus (symmetrische vs. asymmetrische Verschlüsselung, TLS, End-to-End-Verschlüsselung, Festplattenverschlüsselung).
- Organisatorisch müssen Prozesse für das Schlüsselmanagement etabliert, Mitarbeiter geschult und die Nutzbarkeit der Systeme gewährleistet werden.

Nur wenn alle drei Dimensionen berücksichtigt werden, ist Verschlüsselung effektiv. Der Datenschutzbeauftragte fungiert als **Vermittler** zwischen diesen Dimensionen und benötigt ein **T-förmige Kompetenzprofile**: breites Verständnis aller Bereiche mit Vertiefung in mindestens einem der Bereiche.

Diese interdisziplinäre Anforderung spiegelt sich auch in meinem Studium der Politik und Technologie wider: Das Studium zielt darauf ab, politikwissenschaftliche Analysefähigkeiten mit technologischem Verständnis zu verbinden – genau diese Kombination war in der praktischen Datenschutzarbeit für mich essentiell.

---

5. Fazit

Die praktische Tätigkeit als Datenschutz- und Informationssicherheitsauditor hat mir aufgezeigt, dass Datenschutz und Informationssicherheit zentrale Herausforderungen in der digitalen Wirtschaft und Gesellschaft darstellen. Die Analyse zweier sehr unterschiedlicher Praxisprojekte - ein technologieorientiertes Zertifizierungsunternehmen (ICO AG) und eine politische Organisation mit sehr dezentraler Struktur (Partei dieBasis) – verdeutlichte die Vielfalt der Anforderungen und Kontexte.

Zentrale Erkenntnisse:

1. **Interdisziplinarität ist essentiell**: Erfolgreiche Datenschutzarbeit erfordert die Integration rechtlicher, technischer und organisatorischer Perspektiven.
2. **DSGVO als Governance-Instrument**: Die DSGVO ist mehr als eine Compliance-Pflicht – sie kann zur Professionalisierung organisatorischer Datenmanagementprozesse beitragen.
3. **Drittstaatenübermittlungen als Herausforderung**: Die Rechtsprechung des EuGH (Schrems II) hat zu erheblichen praktischen Herausforderungen bei der Nutzung internationaler Cloud-Dienste geführt. Die Spannung zwischen rechtlichen Anforderungen und faktischen Abhängigkeiten bleibt bestehen.
4. **Technische Lösungen allein reichen nicht**: Verschlüsselung, Pseudonymisierung und andere technische Maßnahmen müssen in ein Gesamtkonzept aus rechtlichen, technischen und organisatorischen Maßnahmen eingebettet sein.
5. **Organisatorische Reife entscheidend**: Die Erfahrungen bei der Partei dieBasis zeigten mir, dass technische und rechtliche Lösungen nur wirksam sind, wenn entsprechende organisatorische Strukturen, Verantwortlichkeiten und Ressourcen vorhanden sind.
6. **Politische Dimension**: Der Datenschutz berührt fundamentale demokratische Grundrechte (informationelle Selbstbestimmung, Art. 2 Abs. 1 i.V.m. Art. 1 Abs. 1 GG) und Fragen digitaler Souveränität.

Verbindung zwischen Studium und Praxis:

Die Tätigkeit bei der cironet bot mir eine ideale Möglichkeit, theoretische Konzepte aus dem Studium der Politik und Technologie praktisch anzuwenden:

- **Governance-Theorie**: Die DSGVO als Instrument des „Governance by Regulation" verstehen und umsetzen
- **Technologiebewertung**: Kritische Analyse von Technologien (Cloud, Blockchain, biometrische Authentifizierung) hinsichtlich datenschutzrechtlicher Implikationen
- **Institutionenanalyse**: Untersuchung, wie unterschiedliche Organisationsformen Datenschutzanforderungen umsetzen
- **Policy-Analyse**: Bewertung der Wirksamkeit regulatorischer Instrumente (DSGVO) in der praktischen Anwendung

Umgekehrt schärften die praktischen Erfahrungen meinen analytischen Blick und mein Bewußtsein für ansonsten scheinbar abstrakten, theoretischen Fragen.

Wie wirken rechtliche Normen in organisatorischen Kontexten? Welche Faktoren fördern oder hemmen die Implementierung von Compliance-Anforderungen? Welche politischen und gesellschaftlichen Implikationen haben datenschutzrechtliche Fragestellungen?

Die im Praxisprojekt gewonnenen Erfahrungen bieten mir eine solide Grundlage für die weitere berufliche und wissenschaftliche Auseinandersetzung mit diesen Themen. Sie haben gezeigt, dass die interdisziplinäre Perspektive des Studiengangs Politik und Technologie hochrelevant für die Bewältigung der Herausforderungen der digitalen Gesellschaft ist.

Literaturverzeichnis

[1] COMMUNICATION FROM THE COMMISSION TO THE EUROPEAN PARLIAMENT, THE COUNCIL, THE EUROPEAN ECONOMIC AND SOCIAL COMMITTEE AND THE COMMITTEE OF THE REGIONS A European Strategy for Data (2020). https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:52020DC0066

[2] Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the Protection of Natural Persons with Regard to the Processing of Personal Data and on the Free Movement of Such Data, and Repealing Directive 95/46/EC (General Data Protection Regulation) (Text with EEA Relevance), 119 OJ L (2016). http://data.europa.eu/eli/reg/2016/679/oj

[3] Heckmann, D. (2019). Einführung in die Rechtsinformatik. In D. Heckmann (Hrsg.), juris PraxisKommentar Internetrecht (6. Aufl.). juris.

[4] Bayerischer IT-Sicherheitscluster e.V. (2022). CISIS12: Ein praktikabler Weg zur Informationssicherheit und Datenschutz-Compliance. Regensburg. https://www.it-sicherheitscluster.de/cisis12-isa/

[5] European Court of Justice (2020). Schrems II – Case C-311/18, Data Protection Commissioner v Facebook Ireland Limited and Maximillian Schrems. ECLI:EU:C:2020:559. https://eur-lex.europa.eu/legal-content/EN/TXT/PDF/?uri=CELEX:62018CJ0311

[6] Peter, M. (2021). Kurzbericht zu Vorfällen nach DSGVO und ISO 27001: dieBasis-Partei Bundes-IT. München: cironet data security GmbH & Co. KG. (Unveröffentlichtes internes Dokument).

[7] Peter, M. (2022). dieBasis Datenschutzleitlinie und Informationssicherheits-Konzept V1.0. München: cironet data security GmbH & Co. KG. (Vertrauliches Parteidokument).

[8] cironet data security (2023). ICO AG Datenschutzdokumentation. München: cironet data security GmbH & Co. KG.

[9] Voigt, P., & Bussche, A. (2017). *The EU General Data Protection Regulation (GDPR): A Practical Guide*. https://doi.org/10.1007/978-3-319-57959-7.

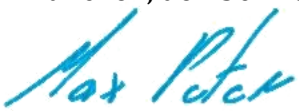
[10] Ohm, P. (2009). Broken Promises of Privacy: Responding to the Surprising Failure of Anonymization (SSRN Scholarly Paper No. 1450006). Social Science Research Network. https://papers.ssrn.com/abstract=1450006.

Eigenständigkeitserklärung

Hiermit versichere ich, dass ich den vorliegenden Praxisbericht selbstständig verfasst und keine anderen als die angegebenen Quellen und Hilfsmittel benutzt habe. Generative KI wurde ausschließlich in untergeordneter Weise als Hilfsmittel für sprachliche Überarbeitung, Strukturierung und Formulierungsvorschläge eingesetzt. Die inhaltliche Konzeption, die Auswahl und Prüfung der Quellen, die fachliche Argumentation sowie alle Bewertungen und Schlussfolgerungen wurden von mir eigenständig vorgenommen. Alle Stellen, die wörtlich oder sinngemäß aus veröffentlichten oder nicht veröffentlichten Schriften entnommen sind, habe ich als solche kenntlich gemacht.

Die während des Praxisprojekts erhobenen und verarbeiteten Daten wurden unter Wahrung der datenschutzrechtlichen Bestimmungen dokumentiert. Für die Nutzung generativer KI wurden keine personenbezogenen Daten, vertraulichen Mandatsinformationen oder sonstigen schutzbedürftigen Inhalte aus dem Praxiskontext in öffentliche KI-Systeme eingegeben. Vertrauliche Informationen wurden nur mit Zustimmung der betroffenen Organisationen in anonymisierter oder pseudonymisierter Form verwendet.

München, den 30. März 2026



Max Peter